



SUPERINTENDENCIA
DE BANCA, SEGUROS Y AFP
República del Perú

Lima, 28 de febrero de 2024

OFICIO N° 12205-2024-SBS

Señores

YVETTE STEPHANY SANGUINETI CAMPOS

Directora de la Autoridad Nacional de Protección al Consumidor

JOSÉ CARLOS VELA VERGARA

Secretario Técnico

**Instituto Nacional de Defensa de la Competencia y de la Protección de la Propiedad Intelectual
INDECOPI**

Referencia: **Oficio N° 000001-2024-ILN-CPC/INDECOPI**

Me dirijo a ustedes con relación a la comunicación de la referencia, por medio de la cual se consulta sobre la interpretación de las disposiciones del Reglamento para la Gestión de la Seguridad de la Información y la Ciberseguridad (Resolución SBS N° 504-2021), en adelante el Reglamento.

¿Se debe entender que el concepto de “canal digital” comprende a terminales de punto de venta POS y cajeros automáticos?

¿Se debe entender que dentro de los alcances del Reglamento se encuentran las páginas web ajenas a una entidad financiera donde los tarjetahabientes pueden realizar operaciones de compra (comercios electrónicos)?

¿Se debe entender que la autenticación reforzada es solo para banca digital, como, por ejemplo, aplicaciones de Banca Móvil y Banca por Internet?

El Reglamento establece lineamientos de carácter general que las entidades financieras deben implementar según el contexto particular de su operación, y no tiene por finalidad establecer una lista limitativa de canales considerados digitales o de describir todas las formas posibles de implementación.

Canal digital

El literal d) del Artículo 2° del Reglamento, establece que un canal digital es cualquier medio empleado por las empresas supervisadas para proveer servicios, cuyo almacenamiento, procesamiento y transmisión se realiza mediante la representación de datos en bits.

En ese sentido, los canales como comercios electrónicos, POS, cajeros automáticos y similares, a través de los cuales las entidades financieras proveen sus servicios a los usuarios, son considerados canales

Los Laureles N° 214 - Lima 27 - Perú Telf. : (511)6309000





SUPERINTENDENCIA
DE BANCA, SEGUROS Y AFP
República del Perú

digitales, en lo que concierne a dichos servicios, en la medida que cumplen con la definición mencionada anteriormente.

Asimismo, en el marco del Reglamento, las empresas del sistema financiero son responsables de autenticar la identidad del usuario cuando este instruya transacciones que lo requieran, como el pago de servicios, tanto en canales propios como de terceros, con la excepción de las operaciones consideradas como micropago, operaciones por montos poco significativos y con un límite máximo que no requieren autenticación reforzada del usuario, por cuyas pérdidas es responsable la entidad financiera, conforme al numeral 6 del artículo 23° del Reglamento de Tarjetas de Crédito y Débito.

¿De qué modo se vería cumplida la autenticación reforzada referida al artículo 19 del Reglamento en cada uno de los supuestos indicados (POS, cajeros automáticos y comercio electrónico)?

La autenticación reforzada en caso se realice una operación de pago en un POS, cajero automático o comercio electrónico se efectúa mediante los factores de autenticación que la entidad financiera implemente y, ponga a disposición de los usuarios en la etapa previa de enrolamiento que realiza la propia entidad financiera.

En una situación común, para las operaciones en POS y cajeros automáticos el primer factor podría consistir en la presencia del chip de la tarjeta; el segundo factor, podría ser la clave secreta (PIN) del tarjetahabiente. Para las operaciones de pago en un comercio electrónico, el primer factor podría consistir en los datos contenidos en la tarjeta, los cuales son registrados por el usuario en la página web o App del comercio electrónico; el segundo factor, podría ser un código de verificación dinámico; o de ser el caso, podría ser omitido por la entidad, bajo su responsabilidad de asumir eventuales pérdidas por operaciones no reconocidas, conforme a las condiciones establecidas para la exención de autenticación reforzada en el artículo 20 del Reglamento.

¿Qué se debe entender por enrolamiento según lo dispuesto por el Reglamento y si ello se encuentra vinculado solo al ingreso al canal (afiliación al canal) o en su defecto a también esa definición se extiende para la validación de una operación?

El enrolamiento al que hace referencia el artículo 18° del Reglamento es el proceso de verificación de identidad de los usuarios que realizan las empresas supervisadas, que tiene como resultado la generación y asignación de credenciales a dichos usuarios antes de la ejecución de operaciones.

Dicha disposición general puede implementarse de variadas formas; tal es así que, el enrolamiento del titular de una tarjeta se efectúa durante la emisión de esta, por única vez para todos los canales de aceptación. Finalizada dicha emisión, estarían generadas y asignadas al usuario las credenciales tales como: el chip de la tarjeta, la clave secreta (PIN), los datos contenidos en la tarjeta y otros según corresponda a la implementación específica. Posteriormente, gracias a dichas credenciales los usuarios pueden efectuar operaciones a través de POS, cajeros automáticos, páginas web de comercios electrónicos, entre otros.

Los Laureles N° 214 - Lima 27 - Perú Telf. : (511)6309000





SUPERINTENDENCIA
DE BANCA, SEGUROS Y AFP
República del Perú

¿Qué finalidad tienen los boletines emitidos por vuestra Superintendencia, es decir, si estos documentos tienen un carácter normativo y complementar las normas emitidas por su entidad o son meramente informativos?

Los boletines que publica la Superintendencia no tienen naturaleza regulatoria, ya que tienen un propósito informativo dirigido a un público general y que aborda diferentes temas, que pueden incluir buenas prácticas y recomendaciones no necesariamente requeridas o reguladas.

Especifique los motivos por los cuales la contraseña de un solo uso (OTP), enviada a través de mensaje SMS, no es considerado como un factor de autenticación válido.

Los factores de autenticación pueden ser de tres categorías posibles, algo que solo el usuario posee, conoce o es. Entre tales categorías, el OTP es implementado de muchas formas, pero tiene por finalidad demostrar que el usuario posee el dispositivo móvil que previamente ha registrado. Sin embargo, los mensajes a través de SMS son susceptibles de interceptación y vulnerables mediante prácticas de ciberdelincuencia (por ejemplo: SIM Swapping). En consecuencia, los OTP enviados por SMS no constituyen un factor de autenticación válido, debido a que no permite verificar que el usuario recibe el OTP en el dispositivo móvil previamente registrado.

Considerando que el artículo décimo del Reglamento establece que entró en vigencia el 1 de julio de 2021, y que, por otra parte, el artículo noveno señala que las disposiciones del Subcapítulo III del Capítulo II tienen un plazo de adecuación hasta el 1 de julio de 2022 ¿Desde qué fecha exacta las entidades financieras se encuentran obligadas a aplicar la autenticación reforzada señalada en el Reglamento?

Las entidades financieras se encuentran obligadas a aplicar la autenticación reforzada desde el 2 de julio de 2022.

Por otro lado, cabe señalar que, con fecha 15 de febrero, esta Superintendencia prepublicó una actualización al Reglamento de Tarjetas de Crédito y Débito, con precisiones sobre la autenticación para operaciones con tarjetas; asimismo, una actualización del Reglamento de Ciberseguridad relacionada a la responsabilidad de las empresas, cuando no se efectúe la autenticación reforzada, entre otras medidas. En dicha actualización se contempla el otorgamiento de plazos de adecuación para implementar los mecanismos de autenticación en operaciones con tarjeta presente y no presente, así como para el reconocimiento por parte de las empresas de operaciones no reconocidas por los usuarios, cuando dichas operaciones no cumplan con los estándares de autenticación.

Atentamente,

CARLOS ENRIQUE MELGAR ROMARIONI
SECRETARIO GENERAL

MCM/dgp

Los Laureles N° 214 - Lima 27 - Perú Telf. : (511)6309000

